

## Guía individual – Análisis del NIST Cybersecurity Framework

### 1. Resumen sobre el NIST Cybersecurity Framework

El NIST Cybersecurity Framework es una guía creada por el NIST de Estados Unidos que sirve para ayudar a las organizaciones a mejorar su seguridad informática. Básicamente, permite que una empresa pueda saber qué cosas tiene que proteger, qué riesgos puede tener y qué puede hacer para evitar o disminuir los problemas de seguridad.

No es una norma que todas las empresas tengan que cumplir obligatoriamente, sino que cada organización puede utilizarla y adaptarla según sus necesidades y posibilidades.

El Framework se divide en cinco funciones principales: Identificar, Proteger, Detectar, Responder y Recuperar. Estas funciones ayudan a llevar un orden a la hora de manejar la seguridad de una empresa, desde conocer los posibles riesgos hasta saber qué hacer después de que ocurre un problema.

Me parece importante porque una empresa no solamente tiene que preocuparse por la seguridad cuando ya sufrió un ataque, sino que también tiene que tratar de prevenirlo y estar preparada por si llega a suceder.

Se relaciona con las amenazas y vulnerabilidades porque una amenaza es algo que puede provocar un daño, mientras que una vulnerabilidad es una debilidad que puede ser aprovechada. Por ejemplo, un virus puede ser una amenaza y tener una computadora sin actualizar puede ser una vulnerabilidad. El Framework ayuda a reconocer estos problemas y a tomar medidas para reducir el riesgo.

### 2. Ejemplos de amenazas y vulnerabilidades

Algunas amenazas que podrían afectar a una organización son:

- **Phishing:** recibir un correo que parece verdadero, pero en realidad busca engañar al empleado para que entregue su contraseña o algún dato importante.
- **Malware:** un programa malicioso que puede entrar en una computadora y provocar problemas, como perder información o impedir que se utilice el equipo normalmente.

Algunas vulnerabilidades podrían ser:

- No capacitar a los empleados: si una persona no sabe reconocer un correo falso, puede caer fácilmente en un ataque de phishing.
- Tener programas desactualizados: los sistemas que no se actualizan pueden tener errores de seguridad que un atacante puede aprovechar.

El Framework ayuda a disminuir estos problemas porque primero permite identificar qué riesgos existen. Después se pueden aplicar medidas de protección, como capacitar a los empleados o actualizar los programas. También permite detectar si ocurre algo extraño, responder frente al ataque y finalmente recuperar los sistemas y la información.

Por ejemplo, si un empleado recibe un correo de phishing, la capacitación puede hacer que se dé cuenta de que es falso y no ingrese sus datos. Y si igualmente alguien cae en el ataque, la organización debería tener medidas para detectar lo ocurrido y actuar rápidamente.

### **3. Función elegida: Proteger**

La función que elegí es Proteger, porque se relaciona con todas las medidas que se pueden tomar para tratar de evitar que un problema de seguridad ocurra o para que sus consecuencias sean menores.

En cuanto a la confidencialidad, se puede proteger la información haciendo que solamente las personas autorizadas puedan acceder a ella.

Para mantener la integridad, se pueden establecer permisos para evitar que alguien modifique o elimine información sin autorización.

Y para la disponibilidad, es importante mantener los sistemas funcionando y realizar copias de seguridad. Si ocurre un ataque y se pierde información, tener una copia permite recuperarla y continuar con las actividades.

Por eso, considero que Proteger es una función importante porque permite tomar medidas antes de que ocurra un problema, en lugar de esperar a que suceda algo para recién actuar.

### **4. Aplicación del NIST Framework en una empresa pequeña**

Si estuviera a cargo de TI de una empresa pequeña, primero trataría de conocer qué equipos, sistemas y datos tiene la empresa y cuáles son los que necesitan mayor protección.

Para proteger la red interna de accesos externos, colocaría un firewall entre Internet y la red de la empresa. Lo configuraría para que solamente permita las conexiones que sean necesarias y bloquee las que puedan representar un riesgo.

También trataría de mantener los equipos y programas actualizados y utilizaría contraseñas seguras. Además, revisaría los registros del firewall para poder detectar si alguien está intentando entrar a la red sin autorización.

Si se detectara un intento de ataque, bloquearía el acceso y revisaría qué ocurrió para evitar que vuelva a suceder. También tendría una copia de la configuración de la red para poder volver a configurarla si se presenta algún problema.

Para proteger la conexión con el ISP, primero revisaría el router o módem que utiliza la empresa y cambiaría las contraseñas que vienen de fábrica. También mantendría actualizado el equipo y revisaría que esté correctamente configurado.

Controlaría la conexión a Internet para detectar si hay caídas o un comportamiento extraño. Si el problema estuviera relacionado con el proveedor, me comunicaría con el ISP para informar lo ocurrido y buscar una solución.

Además, si la empresa depende mucho de Internet para trabajar, tendría alguna alternativa, como otra conexión o datos móviles, para poder seguir funcionando en caso de que la conexión principal se corte.